

Summary of book Privacy-Preserving Machine Learning (Chang, Zhuang and Samaraweera, Manning 2023).

Code implementations can be found in the notebooks folder on the link:

github.com/popchanovska/differential-privacy-intro.

Chapter 1 Summary - Privacy-preserving machine learning

Subsection 1.1 - Privacy complications in the AI era

- This subsection shows several real examples where personal data was leaked or misused.
- In the Facebook-Cambridge Analytica case, a quiz game on Facebook collected data from the people who played it and it also took data from their friends.
- Google developed a tool called RAPPOR, which helps collect user answers while keeping each person's data private.
- In 2021, Google launched its Privacy Sandbox initiative in the Chrome browser, replacing third-party cookies and setting clear limits on how advertising companies can use private data.
- Apple says it first introduced its own well-developed privacy techniques with iOS 11, using them to study things like emoji preferences and usage among iPhone users.

Subsection 1.2 - The threat of learning beyond the intended purpose

- A large amount of our data is collected and stored online every day. This includes web search queries, browsing history, online purchase records, movie preferences and location check-ins. This data is also exposed to insider attacks, because workers at data-mining companies can access it, which is a very serious problem.
- Extra information can sometimes be extracted from private data even when it has been anonymized, or even when the datasets and ML models are hidden and only the test results are shared. At the same time, machine learning is data driven, so we need training samples to build a model.
- The goal is to use private data to train a model while still preventing the algorithm from learning anything sensitive.
- Privacy must be implemented in a systematic way rather than through random methods, because many additional threats have to be considered.
- Organizations follow privacy standards, such as HIPAA, PCI DSS, FERPA and the European Union's GDPR.

Subsection 1.3 - Threats and attacks for ML systems

- It is still difficult to raise public awareness of these privacy technologies, mainly because there are few well-organized tutorials and books that explain the concepts clearly.
- It is important to store private data on the server in encrypted form and we should never send raw data to the server in its original form.
- One important example is when Al-Rubaie and his team studied reconstruction attacks that used raw gesture data from users' authentication profiles in mobile-based continuous authentication systems.
- Simple statistics like the count, mean and median age of a population, broken down by a few demographics, can allow someone with a personal computer to accurately rebuild the personal data of almost the entire survey population.

- With white-box access, malicious insiders have direct access to the ML model, so even with limited knowledge they can still infer what is happening inside.
- With black-box access, the adversary cannot reach the model directly, but they can listen to the incoming requests and the responses the model produces for a given input.

Subsection 1.4 - Securing privacy while learning from data

- Many privacy-enhancing techniques focus on letting several parties train ML models together without releasing their private data in its original form.
- This collaboration can be done using cryptographic approaches or by releasing differentially private data through perturbation techniques.
- Some techniques include differential privacy, local differential privacy (LDP), privacy-preserving synthetic data generation, privacy-preserving data mining techniques and compressive privacy.

Different types of privacy attacks

1. Reconstruction attacks

Here the attacker gains an advantage by having outside knowledge of the feature vectors or the data used to build the ML model. Using this knowledge, they try to rebuild the original data behind the model. These attacks usually require direct access to the model, which is known as white-box access.

2. Model inversion attacks

Some ML models, such as neural networks, do not store feature vectors inside them, so the attacker's knowledge is more limited. Even so, the attacker can listen to the model's responses for new test samples. They then use these responses to recreate data that resembles the original feature vectors used to train the model.

3. Membership inference attacks

This is an extended version of the model inversion attack. Using the model's output, the attacker tries to find out whether a specific sample was part of the training dataset. For example, the attacker might use someone's record to learn whether their data was used to build the model, which can reveal very sensitive information about them.

4. De-anonymization (re-identification) attacks

Even when a dataset has been anonymized, it can still be unsafe. The attacker uses background knowledge to match records back to real people and discover their identities.

5. Correlation attacks

Here the attacker links several different data sources together. This produces more private information about each user than any single dataset held on its own. For example, by combining sources, an attacker could learn which patient bought medication from which pharmacy.

6. Identification attacks

While a correlation attack gathers more private information in general, an identification attack focuses on one specific target person. The attacker links database entries to reveal a lot of personal details about that individual. This is considered one of the most threatening attacks, because it directly harms a single person's privacy.

Chapter 4 Summary - Local differential privacy for machine learning

Chapter overview

- Chapters 2 and 3 covered centralized differential privacy, where a trusted data curator collects everyone's raw data and then publishes private statistics about the group. The problem is that this approach does not work when individuals do not fully trust the curator who holds their data.
- Chapter 4 introduces local differential privacy (LDP), which removes the need for any trusted curator. In LDP, each person changes (perturbs) their own data on their own device before it is ever sent away. The data aggregator then collects all these perturbed values and estimates statistics, such as how often each value appears in the population. Because the data is already privatized, it is very hard for anyone to trace a value back to a single person, which gives people plausible deniability.

Examples for this approach

- Both Google and Apple already use LDP in their products. Google has introduced RAPPOR, which collects statistics from Chrome users while giving strong privacy guarantees. Apple has described how it uses LDP to learn things like trending new words and popular emojis without exposing individual users.
- The chapter shares an example where a company runs a survey with sensitive questions, such as marital status, occupation, age and race. The goal is to keep each person's answers private while still getting an accurate picture of the whole group.

LDP mechanisms

1. Randomized response

This is the oldest and simplest mechanism and it also satisfies LDP. It works well for simple yes/no (binary) questions, such as "Are you married?"

2. Direct encoding

This is used for categorical and discrete answers, such as a person's occupation. Each answer is reported correctly with one probability and changed to another value with a smaller probability.

3. Histogram encoding

This is used for numerical and continuous data, such as a person's age. It comes with two estimation options: summation with histogram encoding (SHE), which simply adds up the noisy reports and thresholding with histogram encoding (THE), which turns values above a threshold into 1 and the rest into 0 to reduce noise.

4. Unary encoding

This is a more general and efficient mechanism for categorical and discrete problems. Each value becomes a binary vector and each bit is flipped with a set probability before being sent. It has two versions: symmetric unary encoding (SUE) and optimized unary encoding (OUE), which differ in how they choose those probabilities.

Chapters 6, 7 & 8 summary - Assuring privacy with data anonymization

Why anonymization is necessary

- Simply removing cells (names, addresses, etc...) from a dataset is not enough to protect privacy.
- An attacker can still combine quasi-identifiers (such as zip code, age and gender) with outside data to re-identify a person.

k-anonymity (subsections 6.2.2, 7.4.2, 8.2)

- k-anonymity hides each person inside a group of similar people.
- A dataset is k-anonymous if every combination of quasi-identifier values appears in at least k records, so each record looks the same as at least k-1 others.
- It is achieved with two main operations: generalization, which makes a value less precise (for example, turning age 24 into the range 20–29) and suppression, which removes a record or value completely, often used for outliers.
- A higher k gives stronger privacy, but it also lowers utility because the data becomes more generalized.
- k-anonymity can still leak information through two attacks.
- In a homogeneity attack, all records in a group share the same sensitive value, so the attacker learns it even without finding the exact record (for example, everyone in the group has cancer).
- In a background knowledge attack, the attacker uses outside facts to narrow the search and infer the sensitive value of a target person.

l-diversity (subsection 8.2.1)

- L-diversity extends k-anonymity.
- It requires that each group contains at least l different (distinct) sensitive values, so an attacker cannot be sure which value belongs to the target.
- A higher l means more variety in the sensitive column and better protection.
- However, l-diversity still has weaknesses: similar values can leak information (for example, two different skin cancers) and an uneven value distribution can cause a skewness attack, where one outcome is clearly more likely than the others.

t-closeness (subsection 8.2.2)

- t-closeness was created to fix the distribution problem in l-diversity.
- The idea is to keep the distribution of sensitive values inside each group close to the distribution in the whole dataset.
- The distance between the two distributions must be no more than a threshold t. This distance is usually measured with metrics such as the earth mover distance, Kullback–Leibler distance, or variational distance.
- By matching the group's distribution to the overall one, t-closeness reduces the information an attacker can gain from skewed data.

The problem of publishing data

- When a dataset is shared with third parties, removing obvious identifiers is not safe on its own. People can still be traced by linking nonsensitive attributes together, which is the linkage or correlation attack. To prevent this, privacy-preserving data mining uses one or more data sanitization operations before publishing.

4 sanitization operations

1. Generalization

- This replaces an exact value with a broader one.

- Eg.: A salary of \$56,000 can become the range \$50,000–\$100,000 and specific job titles can be grouped into "employed" or "unemployed".
- The exact value is hidden, but the general meaning is kept.

2. Suppression

- This removes a record or an attribute from the dataset entirely.
- For example, the name column can be deleted before the medical data is shared.
- It is the simplest way to deal with very sensitive fields or rare outliers.

3. Perturbation

- This replaces real values with altered ones that keep the same statistical properties.
- It can be done by adding random noise, by generating synthetic data from a statistical model, or by data swapping, where sensitive values are exchanged between similar records.
- Data swapping is effective but slow, since it must find a good matching partner for each record.

4. Anatomization

- This keeps the original values but splits the data into two separate tables.
- One table holds the sensitive attributes and the other holds the quasi-identifiers.
- Because the link between them is broken, it becomes much harder to connect a sensitive value to a specific person.